PRESENTER NOTES

Private AI for SAP. Your data never leaves the building.

Speaker's companion document. Detailed talking points, anticipated questions, and technical appendix for each section of the presentation.

Confidential — internal use

SECTION 1 · HERO

Private AI for SAP. Your data never leaves the building.

The 30-second pitch

We help companies that run SAP adopt AI without sending their ERP data to public cloud AI providers. The AI model runs on a dedicated on-premise appliance inside the customer's office. A middleware layer syncs only what the AI needs into an isolated vector database. SAP itself is never touched by the AI.

Why this line matters

- **"Private"** sets the frame: not a cheaper Joule, a fundamentally different trust model.
- **"Never leaves the building"** is the emotional anchor. Compliance teams, CISOs, and works councils all respond to this phrase.

Opening talking points

- Ask the room: "Where is your SAP data right now? Would you be comfortable if that same data sat in a third-party AI vendor's logs for 30 days?"
- Name the elephant: SAP Joule exists. We're not here to replace it for everyone — we're here for the customers who can't or won't use it.

Tone: confident, not defensive. This is a sovereignty story, not a fear story.

SECTION 2 · THE PROBLEM

Why the default options don't work for a large class of SAP customers.

Three real problems

1. **Cloud AI means data leaves the perimeter.** Most public AI providers retain prompts for 30 days for abuse detection. Even with enterprise agreements, prompts transit and are processed outside the customer boundary.
2. **Vendor AI (Joule) is a long-term subscription with no exit.** Per-user, per-month pricing scales with headcount forever. Customer cannot change models, cannot self-host, cannot bring the solution on-prem.
3. **Connecting AI directly to the production DB is dangerous.** Hallucinations on the source of truth, inconsistent query patterns, and performance contention with real ERP workloads.

Who this hits hardest

- Defense and aerospace contractors
- Pharma and life sciences (clinical + trade secret data)
- Banking and insurance (regulator-driven residency)
- EU public sector and sovereign enterprises
- Any customer still on ECC / S/4 on-prem (Joule coverage is limited)

Anticipated pushback

Q: "Our cloud provider is compliant. Why is this a problem?"

A: Compliance is necessary, not sufficient. SOC 2 doesn't change data residency. A SOC 2 provider that processes your data in the US still creates a GDPR transfer question and, more importantly, a perception problem with your own customers and works councils.

SECTION 3 · ARCHITECTURE

One-way flow. SAP stays sealed.

The flow, spoken plainly

SAP is on the left. Everything to the right of SAP is new. Data flows one direction only — out of SAP, never back in — until the very end where users ask questions through the UI. The AI never issues a query against SAP.

Layer by layer

SAP (ECC / S/4HANA)	The existing system of record. Untouched. No AI reads or writes directly.
CDC Layer	Change Data Capture. Options: SAP SLT (Landscape Transformation), ODP (Operational Data Provisioning), or SAP Event Mesh for streaming. Emits only deltas, not full dumps.
ETL + Embeddings Worker	Python service. Filters, redacts PII where not needed, chunks records, generates vector embeddings.
Vector DB	Qdrant, Weaviate, or pgvector. Stores embeddings with RBAC metadata on every chunk (org unit, company code, cost center).
LLM Runtime	Ollama or vLLM running on the on-prem appliance. Loads an open-weight model.
Middleware API	FastAPI. Handles auth, RBAC enforcement, skill dispatch, audit logging.
Internal Web UI	Office network only. No external exposure.

Point to make on the slide

Call out the dashed red box around SAP: **"This is the isolation boundary. The AI has no credentials, no network path, and no mechanism to reach into SAP directly. Everything it knows about the business is mediated by the vector DB and the skills registry."**

Anticipated questions

Q: "Isn't reading from HANA directly faster?"

A: Yes, but it's also unsupported by SAP and couples the AI to schema changes. CDC via supported APIs is the production-correct path.

Q: "How fresh is the vector DB?"

A: Depends on the CDC transport. SLT batch: minutes. Event Mesh streaming: seconds. Tuneable per use case.

SECTION 4 · SKILLS LAYER

The AI doesn't query SAP. It calls typed skills.

What a skill is

A skill is a whitelisted Python function registered with the middleware. Each skill has an input schema, a required permission check, a single well-defined SAP call, and a typed return. The LLM can *request* a skill by name with arguments. The middleware decides whether to run it.

Example skills

- `get_open_invoices(customer_id)`
- `check_stock(material_id, plant)`
- `get_purchase_history(vendor_id, date_range)`
- `create_purchase_req_draft(...)` — draft only; human approves in SAP
- `explain_cost_variance(cost_center, period)`
- `find_similar_materials(query_text)` — retrieval-backed

Why this pattern matters

- **Typed I/O** — the LLM cannot construct arbitrary SQL. It can only pass arguments that match a schema.
- **RBAC enforcement** — every skill call runs under the user's SAP identity, with their authorization objects checked before execution.
- **Audit** — every skill invocation is logged with user, arguments, result size, and timestamp.
- **No write paths without approval** — write skills create drafts only. A human always confirms in SAP.

> **The AI's power is bounded by the skills you give it. Nothing more.**

SECTION 5 · SECURITY

Security model — six non-negotiables.

1. OIDC / SAML authentication

No new identity system. Users sign in with their existing corporate SSO, which maps to their SAP identity.

2. RBAC mirrors SAP authorization objects

Every embedded chunk in the vector DB carries RBAC metadata (org unit, company code, cost center, plant). On every retrieval, the middleware filters by the querying user's SAP authorizations *before* the LLM sees any content. Without this, RAG leaks data across roles. This is the single most important control on the stack.

3. Prompt-injection defense

- Separate system, user, and tool channels
- Strip instruction-like content from retrieved documents before they reach the model
- Output filtering for data exfiltration patterns

4. Immutable audit log

Every prompt, retrieval, skill call, and response is logged. Write-once storage. Queryable by compliance teams.

5. PII redaction at ingest

Names, national IDs, bank details, and other direct identifiers are redacted before embedding unless the use case specifically requires them.

6. mTLS + air-gapped network

Mutual TLS between middleware and the LLM runtime. The LLM host has no outbound internet. Ingress only from the middleware.

Talking point: "Everything the customer's security team already does for SAP — SSO, RBAC, audit — extends to the AI layer without invention. We don't replace their model; we inherit it."

SECTION 6 · COMPLIANCE

Compliance-ready by design.

Standards this architecture maps to

Standard	What our architecture provides
SOC 2 Type II	Immutable audit logging, least-privilege access, change management for skills and model versions.
HIPAA	PHI stays on-premise. No ePHI leaves the customer perimeter. Supports BAA-required controls: access, audit, encryption in transit and at rest.
GDPR	Data minimization (only deltas via CDC), purpose limitation (typed skills), right-to-erasure propagated from SAP to vector DB.
ISO 27001	Controls mappable to ISMS requirements: Annex A.8 (asset management), A.9 (access control), A.12 (operations security), A.18 (compliance).
CCPA / CPRA	Consumer data never sold or shared with AI vendors. Deletion requests propagate across both SAP and vector DB.
FedRAMP-aligned	Architecture patterns compatible with FedRAMP Moderate boundaries for sovereign deployments.

Important caveat to state out loud

Compliance certifications attach to organizations and deployments, not to architectures in the abstract. This architecture is *designed to satisfy* the controls these standards require. The customer's deployment still needs to undergo its own audit.

> **The customer's existing SAP audit posture extends to the AI layer — not the other way around.**

SECTION 7 · HARDWARE

Fits on a desk. Runs the whole office.

Why the appliance matters

A sovereign AI story without credible hardware is vaporware. The customer needs to see something that looks like a product they can buy, rack, and maintain.

The appliance profile

- Apple Silicon M-Ultra class, 192 GB unified memory
- Runs large-class open-weight models locally with usable latency
- Desktop form factor — no datacenter required
- Stackable across branch offices via a simple inference load balancer

How to frame it to a skeptical engineer

- Apple Silicon's unified memory is the unlock — large models fit in RAM without paging.
- Throughput is sufficient for interactive use at office scale (tens of concurrent users per unit).
- Scale-out story: add units per branch or per department, load-balance at the middleware.

If asked about GPUs: "Workstation-class NVIDIA hardware is a valid alternative for customers with existing GPU skill sets. The architecture is model-and-runtime-agnostic. The appliance is a recommendation, not a requirement."

SECTION 8 · VS SAP JOULE

Where we win, where we don't.

Six-point comparison

Dimension	SAP Joule	Private AI for SAP
Data residency	Customer data routed through SAP BTP / hyperscalers	Data stays on the customer's premises
Model choice	What SAP ships	Customer-selected open-weight models; fine-tunable
Cost model	Per-user SaaS subscription, scales with headcount	Capex appliance + flat maintenance; breakeven ~50–100 users
SAP version support	Primarily S/4HANA Cloud	Any SAP version reachable via CDC/APIs — including ECC and on-prem S/4
Roadmap control	Vendor-driven	Customer controls skills, model updates, feature additions
Training-data leakage risk	Contractually governed, varies by product	Structurally zero — no data leaves the perimeter in the default path

Be honest about where Joule wins

- Time-to-first-value: Joule can be turned on in days. Ours needs an implementation.
- Deep SAP UI integration: Joule is embedded in Fiori natively.
- Coverage: Joule ships many pre-built skills out of the box.

Do not pretend otherwise. Credibility comes from acknowledging the trade-off.

SECTION 9 · FALLBACK STRATEGY

When local can't handle it — a ranked fallback.

Tier 1 — Preferred: tiered local models

A small fast model handles the majority of queries (simple retrieval, straightforward summarization). A larger on-prem model handles the hard ones (complex reasoning, long context). Both run on the same appliance. Nothing leaves the building. This is the default path for 95% of use cases.

Tier 2 — Acceptable: sovereign cloud burst with pseudonymization

When local capacity is exceeded or a very large model is required, the middleware may burst to a sovereign cloud endpoint — typically Azure OpenAI in the customer's own region or AWS Bedrock with customer-managed KMS — under a **zero-retention addendum**.

Before any payload leaves the premises, the middleware transforms the data:

1. Strips direct identifiers (names, national IDs, account numbers).
2. Generalizes quasi-identifiers (exact birthdate → age band; exact salary → salary band).
3. Replaces identifiers with deterministic tokens so results can be mapped back locally.
4. Drops free-text fields unless required.

Worked example

Original record: `John Doe · DOB 1984-03-12 · salary €72,000 · Munich office`

What the cloud sees: `Subject_A17F · age band 40–45 · salary band €70–75k · region DE-South`

Cloud returns: `{ tax_owed: €18,400 }`

Middleware re-attaches locally: `John Doe: €18,400`

Caveat to state explicitly: Pseudonymized data remains personal data under GDPR Article 4(5). Tier 2 requires a DPA with the cloud provider, user opt-in per query, and full audit logging. It is not a way to escape GDPR — it is a way to reduce exposure while staying within compliance.

Tier 3 — Never: raw data to public AI APIs

Direct customer data never goes to public consumer AI endpoints. No exceptions. This is what the rest of the architecture exists to prevent.

How to present the ranking

- Tier 1 is the boring answer and it's the right one 95% of the time.
- Tier 2 exists so the customer is never blocked when local can't deliver.
- Tier 3 exists on the slide precisely to say "no."

SECTION 10 · DATA FLOW IN ACTION

One change event, start to finish.

Walk the room through it

1. A finance clerk posts an invoice in SAP.
2. The CDC layer captures the change and emits an event within seconds.
3. The ETL worker consumes the event, redacts anything not needed downstream, chunks the record, and generates a vector embedding.
4. The chunk lands in the vector DB with RBAC metadata (company code, vendor group).
5. Later, an AP manager asks the assistant: "What's outstanding with Vendor X this month?"
6. The middleware authenticates the user, applies their SAP authorizations as a vector-DB filter, and retrieves the relevant chunks.
7. The LLM composes a response and — if needed — requests a skill call like `get_open_invoices(vendor_id)`.
8. The middleware runs the skill under the user's identity, returns the result, the LLM produces a grounded answer, and everything is audit-logged.

Pace

Let the animation play once. Pause. Then verbalize the trust boundary: "Notice that the arrow into SAP, from the AI side, does not exist. It never did."

SECTION 11 · WHY NOW

Three things that make this the right moment.

1. Regulated industries are actively looking for sovereign AI

Defense, pharma, banking, and EU public sector are under increasing pressure to adopt AI without compromising data residency. The demand exists today. The supply — productized on-prem AI for ERP — does not.

2. Open-weight models have crossed the enterprise threshold

Proven open-weight models, US and EU origin, are now capable enough for serious enterprise work. What was a research toy two years ago is a production option today.

3. CDC tooling for SAP is mature

SLT, ODP, and Event Mesh are production-proven. The plumbing for one-way sync exists and has existed for years. We're composing known parts, not inventing new ones.

> **The problem has been real for a decade. The solution parts only clicked into place in the last eighteen months.**

SECTION 12 · CLOSING

SAP stays sealed. AI stays local. You stay in control.

The one-sentence takeaway

If the room forgets everything else, it should remember this: your SAP data is not training someone else's model, not sitting in someone else's log, and not flowing through someone else's network — and your users still get a useful AI.

Suggested closing move

- Do not end on a sales ask.
- End on a question: "What would you want to try first — a read-only pilot on one module, or an end-to-end pilot on a single office?"
- Hand out this document. Offer a follow-up technical deep-dive.

A detailed technical appendix — protocol-level data flow, sample audit events, reference skill specs, and capacity-planning tables — is available as a separate document on request.